

Table of Contents

Cisco Secure Workload — COBIT 2019 Compliance Framework

Reference Design | IT Governance & Assurance Teams

Version: 1.0

Use Case: Fresh Install, Hybrid Environment (On-Prem + Cloud)

Reader's Guide

Who this is for. IT governance, risk, and assurance professionals aligning COBIT 2019 design factors and management objectives with measurable technical evidence; security architects implementing COBIT-aligned controls using workload telemetry and segmentation; and internal audit teams preparing for IT general control (ITGC) or integrated audits where technology evidence is required.

Questions this reference design helps you answer:

- *Which COBIT 2019 management objectives have a direct, repeatable technical expression in Cisco Secure Workload (CSW), versus objectives that remain people-and-process only?*
- *How do I demonstrate continuous monitoring of network connectivity security (DSS05.02) and logical access paths (DSS05.05) using workload-level enforcement and telemetry?*
- *What artifacts support managed performance and conformance monitoring (MEA01) and a managed system of internal control (MEA02) for the subset of objectives CSW addresses?*
- *How can change and configuration management narratives (BAI06, BAI10) be backed by software inventory deltas, ADM drift, and policy baseline comparison?*
- *What evidence exports satisfy an auditor that risk optimization inputs (EDM03) include vulnerability and reachability context for critical services?*

What you'll need. A current application and workload inventory, COBIT 2019 scope (which governance components and management objectives are in audit scope), and either CSW already deployed or documented scope decisions for sensor and connector coverage.

Where to start. Sections 1–4 if you are scoping coverage against COBIT design factors; 5–7 if you are ready to baseline dependencies and design policy; 8–10 if you are collecting audit evidence or preparing governance reporting.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-	Run ADM ≥2	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
	generated flow map	weeks; export clusters; app-owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- DSS05.02 network security continuous proof
- MEA01/02 conformance monitoring from drift exports
- BAI06/10 change evidence from policy audit log

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

COBIT 2019 is an IT governance framework published by ISACA. It organizes guidance around governance principles, design factors, and **40 management objectives** grouped into domains (EDM, APO, BAI, DSS, MEA). Unlike security-specific standards, COBIT spans enterprise goals, organizational structures, and human processes. **Cisco Secure Workload (CSW) maps to a subset of technology-dependent practices**—chiefly objectives where workload visibility, microsegmentation, vulnerability context, and forensic telemetry provide defensible evidence. Objectives concerning culture, sourcing, organizational structures, human resource practices, and pure policy documentation are **out of CSW scope** and must be satisfied by complementary controls.

This reference design focuses on the objectives the user community most often seeks to pair with CSW: security services, operations, monitoring, change/configuration signals, and risk-related technical inputs.

1.1 COBIT 2019 Domains and CSW Relevance (Summary)

COBIT Domain	Focus	CSW Role
EDM (Evaluate, Direct and Monitor)	Governance board direction	Limited; EDM03 gains technical inputs (risk prioritization) from CSW
APO (Align, Plan and Organize)	Strategy and security alignment	APO13 partially: technical enforcement and monitoring of security architecture
BAI (Build, Acquire and Implement)	Delivery and change	BAI06, BAI10: technical signals for changes and configuration state
DSS (Deliver, Service and Support)	Operations and security services	DSS01, DSS02, DSS05 (incl. DSS05.02, DSS05.05): strong CSW

COBIT Domain	Focus	CSW Role
MEA (Monitor, Evaluate and Assess)	Performance and internal control	alignment MEA01, MEA02: dashboards, compliance views, drift and audit exports

2. Pre-Deployment Checklist

Before deploying CSW sensors and connectors, confirm the following:

- ☐ CSW cluster (SaaS or on-premises) is provisioned and reachable from scoped workloads
- ☐ Outbound connectivity from workloads/agents to the CSW cluster (typically TCP 443)
- ☐ Linux and Windows sensor compatibility verified for all in-scope workloads
- ☐ Cloud provider accounts connected (AWS, Azure, GCP) via CSW cloud connectors where applicable
- ☐ Stakeholders identified: IT risk owner, security operations, infrastructure ownership, internal audit liaison
- ☐ Change-management approval obtained for agent installation and eventual enforcement windows
- ☐ Mapping from COBIT in-scope objectives to CSW capabilities documented (this reference design Section 7 as a starting point)

3. Phase 1 — Sensor Deployment (Days 1–5)

3.1 On-Premises Workloads

Install software sensors:

```
# Linux (RHEL/CentOS/Ubuntu family)
sudo rpm -ivh tet-sensor-<version>.rpm      # RHEL/CentOS family
sudo dpkg -i tet-sensor-<version>.deb        # Debian/Ubuntu family
```

```
# Verify the agent service
systemctl status csw-agent || systemctl status tetration-agent
```

Key sensor configuration (COBIT-aligned):

- Enforcement mode: **Monitoring Only** initially (no blocking until baselined)
- Collection: Enable process, network flow, and software inventory where supported; enable vulnerability exposure features for risk workflows (**EDM03, APO13**)
- Tags: Apply governance and ownership metadata from day one, for example `governance:cobit, domain:DSS, criticality:high, owner:it-ops`

3.2 Cloud Workloads (AWS / Azure / GCP)

Option A — Software sensor on cloud VMs: Same installation pattern as on-premises.

Option B — CSW cloud connectors (agentless inventory/flow context):

CSW UI → Platform → External Orchestrators
→ Add AWS / Azure / GCP connector
→ Attach least-privilege IAM role (AWS) or service principal (Azure)
→ Enable flow log or cloud network telemetry ingestion per vendor guidance

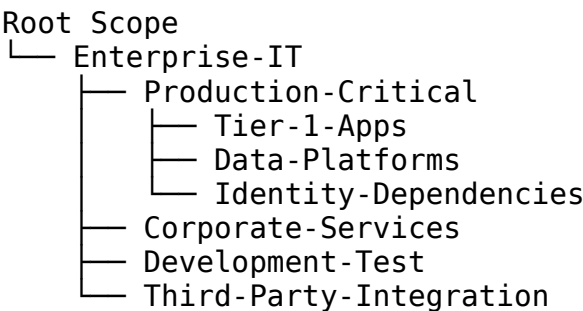
3.3 Sensor Validation

CSW UI → Manage → Agents
→ Confirm agents are Active and versions are standardized
→ Verify telemetry (flows/process events) visible for each scope pilot

4. Phase 2 — Scope and Inventory Design (Days 6–10)

4.1 Governance-Aligned Scope Hierarchy

Design scopes to mirror how the enterprise manages services and risk, not only network topology:



Align labels with COBIT accountability (roles are organizational; labels are technical anchors for evidence):

Label Key	Example Values	COBIT Tie-In
cobit_domain	DSS, BAI, MEA	Reporting filters for objective owners
service_tier	tier0, tier1, tier2	Prioritization for EDM03 / APO13
owner_team	app-name + ops team	Traceability for DSS01 operations narratives
data_class	regulated, internal, public	Scope for logical access policy (DSS05.05)

4.2 Inventory Filters for Critical Platforms

Filter: Identity-and-Directory

- Process: samba, krb5kdc, sssd, ntp, named
- Ports: 389, 636, 88, 464

Filter: Data-Tier

- Process: mysqld, postgres, oracle, sqlservr, mongod, redis-server
- Ports: 3306, 5432, 1521, 1433, 27017, 6379

Filter: Admin-Tooling

- Process: sshd, winrm, MMC-related patterns (validate in your environment)
 - Use for ****DSS05.05**** logical path reviews (not identity MFA)
-

5. Phase 3 — Visibility, Baseline, and ADM (Days 11–21)

5.1 Application Dependency Mapping (ADM)

ADM establishes the observed communication graph—foundational for **DSS05.02** (network and connectivity security) and for validating that **managed operations (DSS01)** reflect reality.

CSW UI → Investigate → Application Dependency Mapping

- New Workspace
- Name: "COBIT-DSS-Baseline-ADM"
- Scope: Production-Critical (expand iteratively)
- Time window: 2–4 weeks (cover month-end and change windows)
- Start ADM

ADM settings:

- Enable **process context** on connections
- Enable **user context** where the sensor supports it (**DSS05.05** logical access path analysis)
- Retain sufficient history for **MEA01** trend reporting (minimum 30 days; align to internal record retention)

5.2 Baseline Questions Mapped to COBIT Objectives

Question during ADM review	Primary COBIT objective
Which tier-1 workloads accept inbound connections from non-production?	DSS05.02, APO13
Are administrative paths constrained to jump hosts or shared tooling?	DSS05.05
What external SaaS or partner networks do critical apps rely on?	DSS01, DSS05
Did new software versions appear	BAI06

Question during ADM review

Primary COBIT objective

without a matching change ticket?

Did listener ports or processes change against an approved baseline? **BAI10**

5.3 Change and Configuration Signals (**BAI06, BAI10**)

Use CSW to **detect** technical drift; pair with ITSM for **authorize**:

Example: export inventory snapshot via CSW API/UI on a schedule (pseudo-workflow)
1. CSW UI → Investigate → Inventory → Export CSV (weekly)
2. Diff against prior week for: new packages, new listening ports, new long-lived processes
3. Attach diff to change record or exception register

Operationalize: schedule **weekly inventory exports** and **90-day ADM re-baselines** for tier-1 scopes.

6. Phase 4 — Policy Design and Enforcement (Days 22–35)

6.1 COBIT-Oriented Policy Workspace

Translate DSS connectivity and access objectives into CSW segmentation policy:

Illustrative absolute policies (tune to your ADM):

DENY: Development-Test → Production-Critical (all ports)
DENY: Production-Critical → Internet (default; allow explicit egress exceptions only)
DENY: Any-NonJumpHost → Production-Critical (ports 22, 3389, WinRM ranges)

Illustrative allowlist policies:

ALLOW: Tier-1-Apps → Data-Platforms (application-specific ports from ADM)
ALLOW: Tier-1-Apps → Identity-Dependencies (LDAPS 636 / Kerberos as validated)
ALLOW: Monitored-Jump-Host → Production-Critical (admin ports, source-locked)
ALLOW: Production-Critical → Corporate-Patch-Mirror (update paths only)
ALLOW: Scoped-Workloads → CSW-Cluster (443 to telemetry endpoints)

Catch-all instrumentation:

LOG: unmatched inbound to Production-Critical
LOG: unmatched outbound from Production-Critical
ALERT: first-seen external destination from Tier-1-Apps

6.2 Policy Workspace Setup

CSW UI → Defend → Segmentation
→ New Workspace
→ Name: "COBIT-DSS05-Production"
→ Scope: Production-Critical
→ Import ADM-recommended rules → refine with owners
→ Mode: Simulation → Enforcement (staged)

6.3 Enforcement Progression

Stage	Mode	Duration	COBIT intent
1	Simulation	2+ weeks	MEA01 — observe deviation before blocking
2	Selective enforcement	1–2 weeks	DSS05.02 — reduce connectivity risk incrementally
3	Full enforcement (approved ruleset)	Ongoing	AP013 / DSS05 —sustained technical control

7. Phase 5 — Control-by-Control Mapping

The table below maps **selected COBIT 2019 management objectives and focus areas** to CSW capabilities and **representative evidence**. COBIT component practices (activity-level detail) should be mapped in your internal control library; CSW addresses the **technology** slice only.

COBIT objective / focus area	CSW capability	Evidence produced
AP013 Managed Security	Microsegmentation workspaces; always-on flow/process telemetry; vulnerability exposure views	Policy workspace exports; simulation vs enforcement reports; alerting history; risk- prioritized exposure reports
DSS01 Managed Operations	Continuous flow and process monitoring; inventory; operational dashboards	Flow search exports; inventory CSV; agent health views; top-talkers and dependency maps
DSS02 Managed Service	Forensic flow and	Incident-timeline

COBIT objective / focus area	CSW capability	Evidence produced
Requests and Incidents	process search; parent/child process context	exports; filtered flow captures; process execution chains for IoC windows
DSS05 Managed Security Services	Segmentation enforcement; network visibility; optional integration points for detection workflows	Block/allow decision logs; policy hit counts; segmentation coverage reports
DSS05.02 Network and Connectivity Security	Microsegmentation; explicit allow/deny; east-west visibility	ADM graph snapshots; enforced policy JSON/YAML exports; violation alerts
DSS05.05 Physical and Logical Access	Logical path restriction (network layer); visibility into admin tooling paths <i>Note: identity, MFA, and physical access remain out of scope</i>	Rules restricting admin ports to jump hosts; flows showing actual paths used
MEA01 Managed Performance and Conformance Monitoring	Compliance dashboards; policy conformance; trend reporting	Scheduled dashboard PDF/exports; conformance % over time; SLA-style reporting packs
MEA02 Managed System of Internal Control	Drift detection (inventory vs baseline); policy versioning; audit exports	Weekly diffs; policy baseline checksum/history; signed export bundle for auditors
BAI06 Managed IT Changes	New packages, listeners, and dependencies surfaced post-change	Inventory delta reports; ADM diff after change window; correlation to ITSM IDs (manual link)
BAI10 Managed Configuration	Baselined listeners/process sets; scope hygiene	Baseline exports; non-compliant workload list; scope membership snapshots
EDM03 Ensured Risk Optimization	CVE awareness with reachability/exposure context; prioritization for patching	Vulnerability reports filtered by tier; reachability analysis outputs; executive risk

COBIT objective / focus area	CSW capability	Evidence produced summaries
------------------------------	----------------	-----------------------------

8. Phase 6 — Vulnerability, Reachability, and Risk Inputs (**EDM03, APO13**)

8.1 Vulnerability and Exposure Reporting

CSW UI → Investigate → Vulnerability Report

- Scope: Production-Critical
- Filters: business tier, CVSS, EPSS (where available), known exploit context
- Export for risk committee / audit working papers

8.2 Prioritization Pattern

1. **Internet- or partner-exposed** workloads with critical CVEs (patch or segment first)
2. **Lateral** reachable high-value workloads from compromised entry points
3. **Deep** internal workloads with CVEs but no observed risky paths (document compensating segmentation)

9. Phase 7 — Monitoring, Drift, and Audit Evidence (**MEA01, MEA02**)

9.1 Monitoring Patterns

Monitor	Trigger	COBIT relevance
Policy violation rate spike	Sudden blocks or denies	DSS01, DSS05
New external destination	First-seen egress	DSS05.02, APO13
Inventory delta	New high-risk packages	BAI06, BAI10
Agent offline	Loss of visibility	MEA01, DSS01
Scope drift	Untagged assets in tier-1 subnets	MEA02

9.2 Forensic Use (**DSS02**)

CSW UI → Investigate → Flow Search

- Time range: incident window
- Source/Destination: affected workload or subnet
- Export: CSV/JSON with process attributes

CSW UI → Investigate → Process Search

- Filter: workload + time + suspicious parent chain
- Export for IR retention index

Align retention with enterprise records management; CSW exports are **copies** for legal/audit holds.

10. Boundaries — What CSW Does **Not** Cover

Document these explicitly in control narratives to avoid over-claiming COBIT satisfaction:

- **Governance culture, board oversight, and management accountability** (EDM broadly): CSW is not a governance operating model.
 - **Human resources, competencies, and behavior** (numerous APO/BAI practices): out of scope.
 - **Third-party contractual and procurement controls**: CSW does not manage vendor SLAs or contract clauses.
 - **Physical security**: no facility controls; only **logical** network path restrictions.
 - **Identity lifecycle, credentials, MFA, and authorization decisions** (IdP/PAM): CSW does not replace IAM; it **restricts network paths** and **observes** process behavior.
 - **Full SOX/financial controls or GRC workflow**: integrate CSW exports into your GRC tool; CSW is not a controls library.
 - **All 40 COBIT objectives**: this reference design targets **technology-evidence-friendly** objectives; others require policy, process, and other tools.
-

11. Audit Preparation and Evidence Export

11.1 Typical Evidence Package (Quarterly or Audit Window)

Evidence item	CSW source	Suggested frequency	Mapped objectives
Segmentation policy workspace export	Defend → Segmentation	Each release + quarterly	DSS05.02, APO13
Simulation vs enforcement acknowledgement	Policy lifecycle records	Per cutover	MEA02
ADM baseline snapshot	Investigate → ADM	90 days	DSS01, BAI10
Inventory baseline + delta	Investigate → Inventory	Weekly/monthly	BAI06, BAI10
Vulnerability + reachability summary	Investigate → Vulnerability	Monthly	EDM03
Alert and violation extracts	Alerts / SIEM forward	Incident + sample periods	DSS02, MEA01

Evidence item	CSW source	Suggested frequency	Mapped objectives
Agent coverage report	Manage → Agents	Monthly	MEA01

11.2 Control Testing Tips

- **Design effectiveness:** Show that tier-1 scopes are fully sensor-covered and enforcement mode matches policy intent.
- **Operating effectiveness:** Sample time windows; pull flows proving denied paths remain denied; verify drift tickets exist for inventory anomalies.
- **Gap handling:** If a COBIT practice requires HR training or vendor attestations, keep CSW evidence **adjacent** (same control ID) but **not substitutive**.

11.3 Bash-Oriented Automation Hooks (Illustrative)

Integrate with your CI or SOC tooling; adjust endpoints to your CSW deployment:

```
#!/usr/bin/env bash
set -euo pipefail
# Illustrative: archive weekly inventory export from a secured jump host
DATE=$(date +%F)
EXPORT_DIR="/secure/evidence/csw/${DATE}"
mkdir -p "${EXPORT_DIR}"
# Replace with your approved CSW API/export mechanism:
# curl -sS -H "Authorization: Bearer ${CSW_API_TOKEN}" \
#   "https://<csw-cluster>/api/v1/inventory/export?scope=tier1" \
#   -o "${EXPORT_DIR}/inventory-tier1.csv"
echo "Placeholder: perform UI or API export into ${EXPORT_DIR}"
sha256sum "${EXPORT_DIR}/*" > "${EXPORT_DIR}/MANIFEST.sha256" || true
```

Note: Use your organization’s approved API tokens, IP allow lists, and secrets management—never embed live tokens in scripts committed to repositories.

12. Common Pitfalls

Pitfall	Mitigation
Asserting CSW satisfies an entire COBIT objective	Decompose to practices; attach CSW evidence only to technology-addressable practices
Mapping DSS05.05 to IAM or MFA	Keep narrative precise: CSW enforces logical network paths and observes admin tooling; IdP/PAM owns identity
Skipping simulation before enforcement	Run segmentation in simulation long enough to capture batch and admin

Pitfall	Mitigation
ADM window too short for BAI06 / BAI10	windows (MEA01) Use minimum 2–4 weeks; include known change freezes and releases
Tier-1 assets missing agents	Treat coverage gaps as MEA02 control deficiencies until remediated
Policy drift undocumented	Version policy exports; store checksums or Git-backed artifacts alongside change tickets

Appendix A — COBIT and ISO/NIST Cross-Walk (Orientation)

Many enterprises map COBIT to ISO/IEC 27001 or NIST SP 800-53. CSW technical evidence generated for connectivity security and monitoring often **feeds** those mappings even when the audit framework is COBIT-first. Maintain a single **evidence repository** keyed by control ID to avoid duplicate work.

Appendix B — Related Frameworks

- [NIST SP 800-53 Rev 5](#) — detailed security control language often used alongside COBIT in regulated enterprises.
- [ISO/IEC 27001:2022](#) — ISMS audits frequently pair with COBIT governance reviews.
- [NIST SP 800-207](#) — zero trust architecture patterns underpinning segmentation evidence for **DSS05.02**.
- [UK NCSC CAF v3.2](#) — APO13 is the reuse path for CAF A1 governance telemetry.

Document prepared for Cisco customer engagements. Replace bracketed placeholders and tailor scopes to your COBIT assessment boundary before external sharing.